802.1x

La sécurité au sein d'un réseau câblé amenée par l'authentification des utilisateurs au moyen d'équipements de réseau « 802.1x » couplés à un serveur RADIUS

Constatation

- Si des dispositifs existent pour sécuriser les accès depuis l'extérieur (DMZ, Pare-feux…) ou par les technologies sans-fil, force est de constater que les prises murales des réseaux des entreprises sont souvent accessibles et ouvertes, sinon au quatre vents, du moins sur des segments entiers de réseaux.

- La technologie 802.1x peut répondre à ces éventuels manquements à la sécurité. Elle peut apporter également plus de souplesse dans la gestion des VLAN.

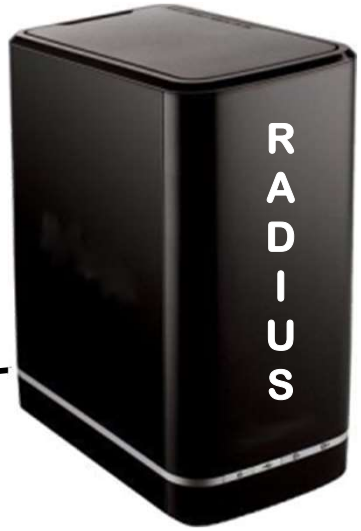
Principes 802.1x

Les acteurs en présence

Le « chef »

Équipement de réseau relayant la demande : Le « client RADIUS »

Le « quidam »



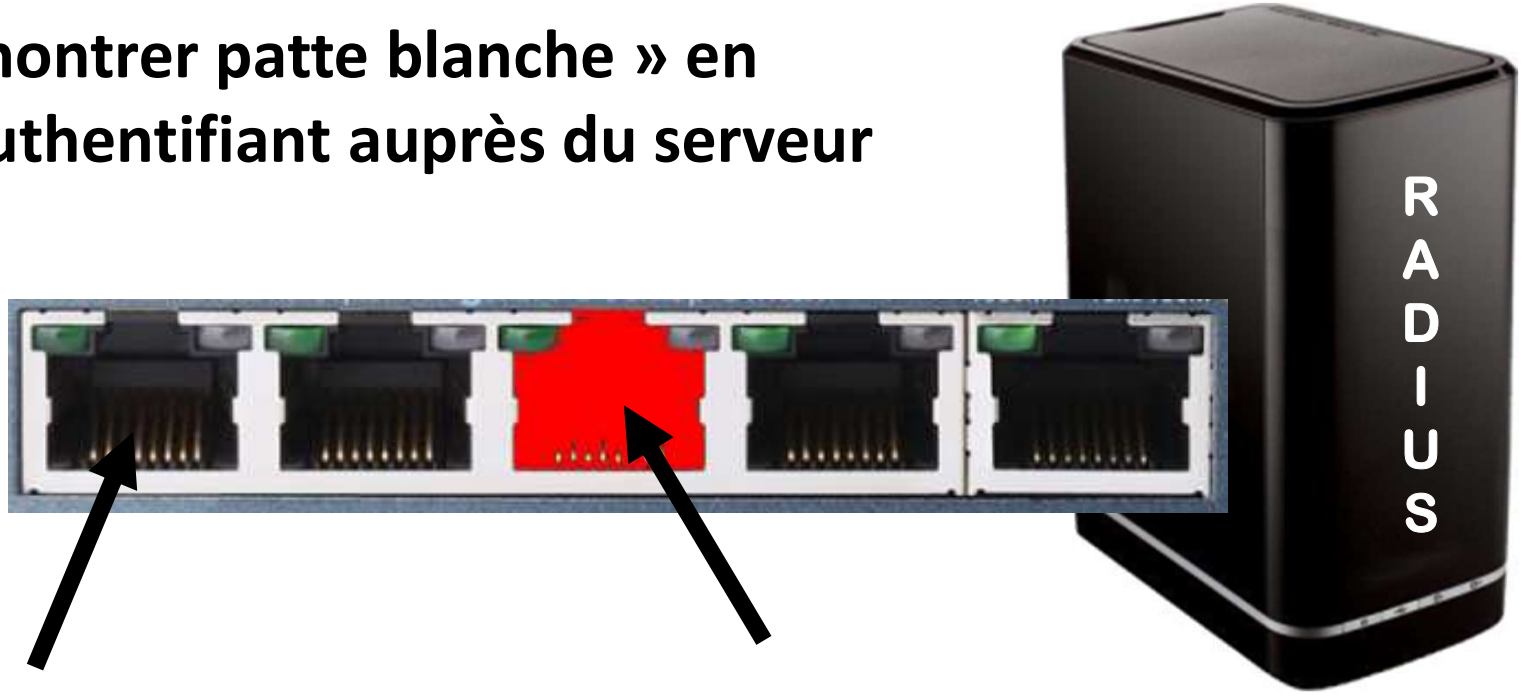
Ordinateurs demandant l'accès au réseau : les « supplicants »

Le « gardien »

Serveur acceptant - ou refusant - la demande : « Serveur RADIUS »

Principes 802.1x

Les ports des équipement réseau en mode 802.1x ne sont plus en accès libre, mais il y a un préalable à leur utilisation : le client final doit « montrer patte blanche » en s'authentifiant auprès du serveur



Port N°1 en mode standard d'accès libre ouvert à tous

Port n°2 en mode « 802.1x » d'accès restreint aux clients *authentifiés*

Principes 802.1x

Comment un client peut-il s'authentifier si toute communication lui est refusée ?

➡ Grâce à l'acceptation, par le port non contrôlé des seuls paquets du protocole EAP **qui ne peut servir qu'à l'authentification**

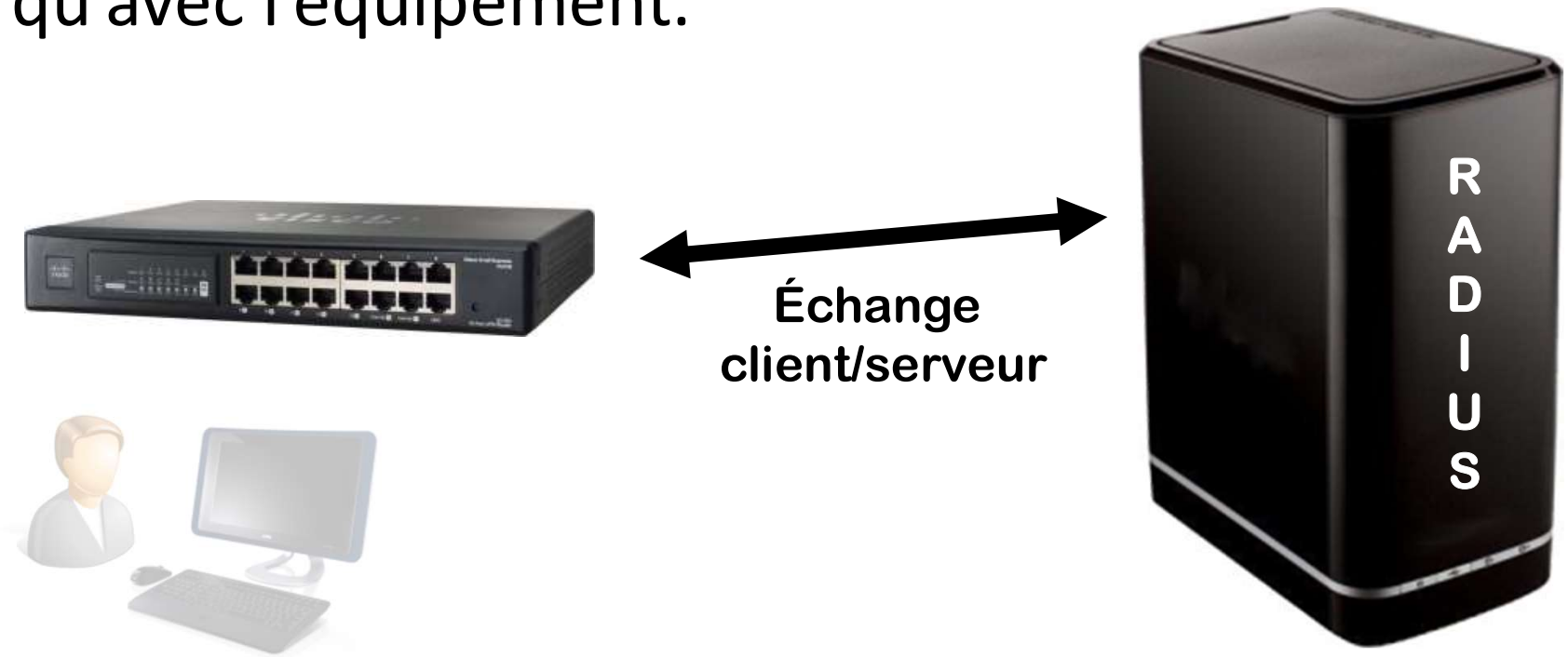
➡ Après authentification, tous les types de paquets seront acceptés.

Avant authentification

Après authentification

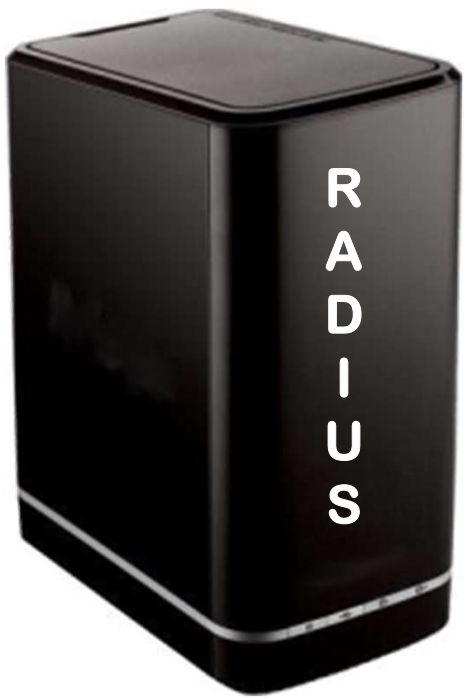
Principes 802.1x

Les équipements de réseau 802.1x sont les seuls clients du serveur Radius.
Le client final ne connaît pas l'adresse du - ou des - serveurs Radius et il n'est autorisé qu'à communiquer qu'avec l'équipement.



Principes 802.1x

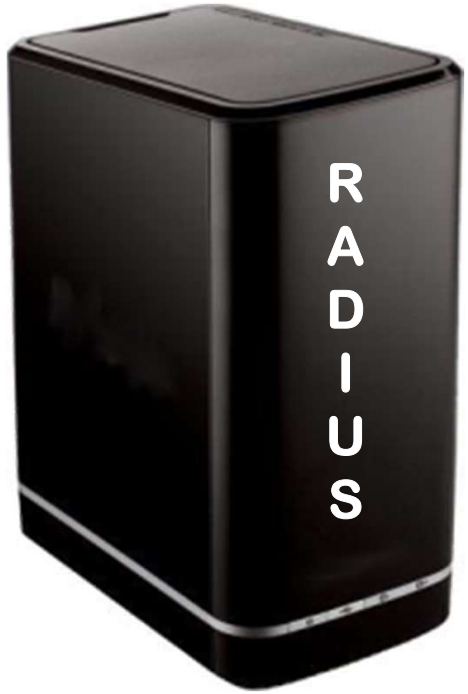
Le serveur Radius met en œuvre les règles régissant l'acceptation ou non des demandes transmises par ses clients. Il interroge un annuaire ou une base de données SQL d'utilisateurs



Principes 802.1x

Quelles conséquences, en cas d'acceptation ?

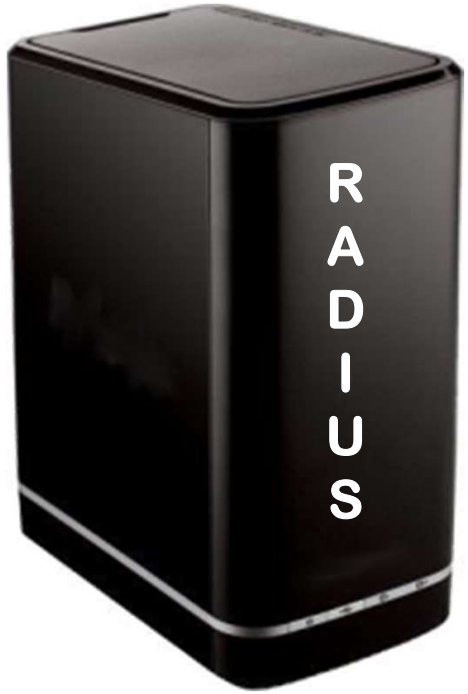
- autorisation d'accès pure et simple
- placement dans un VLAN dédié à l'utilisateur
- Autres stratégies …



Principes 802.1x

Quelles conséquences, en cas de refus?

- Refus de communication pur et simple
- Placement en quarantaine (un VLAN particulier) géré par l'équipement



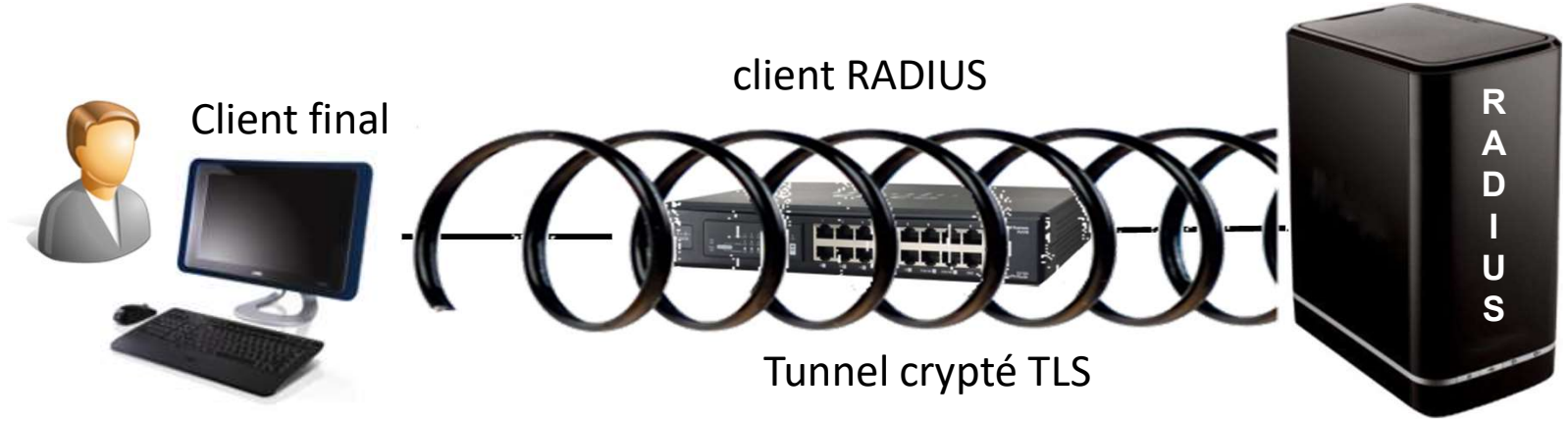
Principes 802.1x

Quelles peuvent être les règles d'acceptation ?

- Utilisateur membre d'un groupe d'annuaire autorisé
- Horaire autorisé
- Adresse MAC autorisée
- « Propreté » du poste en terme d'antivirus, de mises à jour système …

Principes 802.1x

Articulation EAP / PEAP / MS-CHAP-V2



EAP : seul protocole de communication autorisé entre le client Radius et le client final non encore authentifié. Principe de base de 802.1X

PEAP : Protected EAP : ajout de la notion de tunnel TLS : les échanges cryptés sont transportés par EAP. Objectif : rendre invisible la nature de l'échange

MS-CHAP : méthode de reconnaissance mutuelle du client final et du serveur Radius passant par le tunnel crypté TLS.